

Tietoturva-auditointi – Viitekehysten kartoitus

Tähän dokumenttiin kartoitetaan PK-yrityksen tietoturva-auditointiin sopivat viitekehykset. Jokaisesta viitekehyksestä kirjoitetaan lyhyt kuvaus, sen hyödyt PK-yritykselle ja keskeiset osa-alueet, joita se kattaa.

Viitekehys	Kuvaus	Hyödyt PK-yritykselle	Keskeiset osa-alueet
Traficom / Kyberturvallisuuskeskus – Tietoturvaopas pk-yrityksille	Suomen Kyberturvallisuuskeskuksen laatima opas pk-yrityksille tietoturvan parantamiseen. Antaa konkreettisia ohjeita tietoturvan perustason varmistamiseen. Ilmainen.	Tarjoaa suomenkielisen ja selkeän mallin, joka ei vaadi erityistä teknistä asiantuntemusta. Soveltuu käytettäväksi heti arjen toiminnassa.	Tietoturvapolitiikka, salasanakäytännöt, ohjelmistojen päivitys, varmuuskopiointi, henkilöstön koulutus, käyttöoikeuksien hallinta.
ISO 27001/27002	Kansainvälinen standardi tietoturvan hallintajärjestelmän rakentamiseen ja hallintaan. ISO 27002 täydentää ohjaamalla konkreettisiin kontrollitoimenpiteisiin. Maksullinen.	Auttaa jäsentämään ja systematisoimaan tietoturvaa. Mahdollistaa auditoinnin ja kehittämisen tunnetun kansainvälisen mallin pohjalta.	Riskienhallinta, tietoturvapolitiikka, henkilöstön turvallisuus, käyttöoikeuksien hallinta, fyysinen turvallisuus, jatkuvuuden hallinta.
NIST Cybersecurity Framework	Yhdysvaltain standardointiorganisaation (NIST) kehittämä tietoturvakehys, jaettu viiteen päätoimintoon. Käytössä kansainvälisesti eri kokoisissa organisaatioissa.	Antaa selkeän rakenteen tietoturvan kehittämiseen. Voidaan soveltaa joustavasti pk-yrityksen resurssien mukaan.	Identify (tunnista), Protect (suojaa), Detect (havaitse), Respond (reagoi), Recover (palauta).

Lähteet:

<https://www.kyberturvallisuuskeskus.fi/fi/ajankohtaista/ohjeet-ja-oppaat/ohjeet-ja-oppaat-organisaatioille-ja-yrityksille>

<https://www.iso.org/standard/27001>

<https://www.bsigroup.com/en-GB/products-and-services/standards/iso-iec-27001-information-security-management-system/>

<https://www.nist.gov/cyberframework>